XYZ – Technology Services

Information Security Management System Manual

Document Number: XYZ-TS-IS-MN-001

Classification: Internal

Owner: Chief Digital Officer (CDO)

Effective Date: 15-Sep-2021

CS5292 W6 · D02 · sanitised for teaching

Document History:

Release Date	Revision No	Author(s)	Description	Reviewed & Approved By	Next review date
15-Sep-2021	1.0	ISO	Approved Document	ISMC	Sep-2022

CS5292 W6 · D02 · sanitised for teaching

Table of Contents

1. Purpose 5
2. Policy Document Management 5
2.1. Distribution 5
2.2. Enforcement 5
2.3. Non-adherence and Disciplinary action 5
2.4. Version History Control 5
2.5. ISMS Manual Review 6
3. Information Security Management System 7
3.1. Introduction 7
3.2. Objectives 7
3.3. Scope 8
3.4. ISMS Organization 8
3.4.1. General 8
3.4.2. Organization Structure 8
3.4.3. Documentation Approval Authority 8
4. Context of the Organization 9
4.1. Understanding the organization and its context 9
4.2. Understanding the needs and expectations of interested parties 9
4.3. Determining the scope of the information security management system 9
4.4. Information Security Management System 9
5. Leadership 10
5.1. Leadership and Commitment 10
5.2. Policy 10
5.3. Organization Roles, Responsibilities and Authorities 10
6. Planning 11

CS5292 W6 · D02 · sanitised for teaching

6.1. Actions to Address Risks and Opportunities 11
6.1.1. General 11
6.1.2. Information Security Risk Assessment 11
6.1.3. Information Security Risk Treatment 11
6.2. Information Security Objectives and Planning to Achieve Them 12
7. Support 13
7.1. Resources 13
7.2. Competence 13
7.3. Awareness 13
7.4. Communication 14
7.5. Documented Information 14
7.5.1. General 14
7.5.2. Creating and Updating 15
7.5.3. Control of Documented Information 15
8. Operation 17
8.1. Operational Planning and Control 17
8.2. Information Security Risk Assessment 17
8.3. Information Security Risk Treatment 17
9. Performance Evaluation 18
9.1. Monitoring, Measurement, Analysis and Evaluation 18
9.2. Internal Audit 18
9.3. Management Review 19
10. Improvement 20
10.1. Nonconformity and Corrective Action 20
10.2. Continual Improvement 20

CS5292 W6 · D02 · sanitised for teaching

1. Purpose

The purpose of this manual is to define the implementation method of the requirements stated in the ISO/IEC 27001:2013 standard.

2. Policy Document Management

2.1. Distribution

This is an internal document and should only be shared with employees at XYZ - Technology Services (hereafter referred to as "XYZ-TS") and intended parties determined by the Information Security Officer (ISO).

2.2. Enforcement

All employees, stakeholders and third-party vendors having access to information and information systems of XYZ-TS shall comply with the XYZ-TS Information Security Policies. Such personnel should be required to execute an agreement with XYZ-TS agreeing to abide by the Policy.

2.3. Non-adherence and Disciplinary action

All violations and attempted violations of the XYZ-TS Information Security Management System Manual by the employees of XYZ-TS shall result in disciplinary action instituted by Human Resources (HR) Division in consultation with the Information Security Management Committee (ISMC) wherever appropriate. Disciplinary action shall be consistent with the severity of the incident, as determined by an investigation as per the laid down HR disciplinary procedures.

All violations and attempted violations of the Information Security Policies by third party service providers shall result in appropriate action being instituted in terms of the terms and conditions of the Agreements entered into with such service providers.

All violations of the Information Security Policies must be reported to the ISO.

2.4. Version History Control

It is the responsibility of ISMS Manual holders to ensure that additions and amendments are inserted into the ISMS Manual whenever change occurs and the copies of superseded policies, procedures or documents are discarded.

CS5292 W6 · D02 · sanitised for teaching

Master copies of superseded documents are secured by the ISO as archive for future reference.

The numbering system will be as per the XYZ-TS ***Mandatory ISMS Procedures*** (XYZ-TS-IS-PR-002).

2.5. ISMS Manual Review

The ISMS Manual and all the policies will be reviewed once in a year or as per the requirement arises in the organizational structure or roles and responsibilities of the ISMS are affected. Review shall incorporate changes in business objectives or the risk environment.

The review document will follow the document change management process as outlined in Procedure for XYZ-TS ***Mandatory ISMS Procedures*** (XYZ-TS-IS-PR-002).

CS5292 W6 · D02 · sanitised for teaching

3. Information Security Management System

3.1. Introduction

Information Technology plays a critical role in XYZ-TS business operations. IT infrastructure and services provide high levels of value additions in terms of time, knowledge, convenience and money. All the critical business functions are increasingly dependent on the IT infrastructure and services for their daily business operations, decision making and business support systems.

The dependence on IT, in turn, raises concerns over the safety and security of all the information assets and thus creates a need for an integrated approach for protecting vital assets of the organization that are dependent on IT.

In order to protect all the critical information assets and to practice a coordinated approach, an ISMS is being introduced for all the critical information assets. When implementing the ISMS, the focus will be on fulfilling the business objectives, statutory and regulatory requirements, requirements of interested parties and following a process approach which, in turn, will be an on-going one with knowledge management, periodic review and continual improvement.

3.2. Objectives

The objectives of implementing ISMS based on ISO/IEC 27001:2013 within XYZ-TS will be:

a) Continuously follow the risk management process to identify and mitigate the information security risk related to the XYZ-TS information assets and projects.;
b) Ensure the effectiveness of Disaster Recovery and Business Continuity plan by reviewing and testing in timely manner.
c) Maintain an appropriate level of awareness, knowledge and skills to minimize the occurrence and severity of information security incidents at XYZ-TS.
d) Maintain an effective information security incident management process to timely respond to security incidents and minimize such incidents.
e) Provide a secure and better service for XYZ-TS employees/users and its stakeholders.
Objectives are outline in **ISMS Objective Document** (XYZ-TS-IS-RG-002)

CS5292 W6 · D02 · sanitised for teaching

3.3. Scope

Scope of ISMS is outlined in the latest version of ***ISMS Scope Document*** (XYZ-TS-IS-MN-002).

3.4. ISMS Organization

3.4.1. General

The Management of XYZ-TS shall establish to operationalize documented information security Organization structure, with clearly laid down roles and responsibilities.

3.4.2. Organization Structure

Organizational Structure is outlined in the latest version of ***Information Security Roles & Responsibilities document*** (XYZ-TS-IS-PR-018)

3.4.3. Documentation Approval Authority

Appropriate authorities are defined for control of documents involved in Information Security Management System as under:

Sl. No	Type of Document	Activity	
		Approved by	Maintained by
1	Information Security Management System Manual	ISMC	ISO
2	ISMS Procedures	ISMC	ISO
3	Statement of Applicability	ISMC	ISO
4	Acceptable Usage Policy	ISMC	ISO
5	Risk Assessment, risk mitigation and other management documents	ISMC	ISO
6	Divisional SOP (like HR and Admin process related) documents, if any	Relevant Head of Divisions	

CS5292 W6 · D02 · sanitised for teaching

4. Context of the Organization

4.1. Understanding the organization and its context

ISMC together with the other divisional heads shall discuss and list down any external and internal issues pertaining to information security.

These issues must be carefully evaluated, and an action plan shall be established after evaluating to the risk as per the information security risk assessment process.

The issues will be discussed during the management review and updated on a timely manner. The external and internal issue list shall be as per the latest version of ***Context of the Organization*** (XYZ-***TS-IS-RG-001).***

4.2. Understanding the needs and expectations of interested parties

ISMC together with other divisional heads shall identify the interested parties that are relevant to the ISMS.

Needs and expectations of the interested parties are being documented in a register and updated in a timely manner. The need and expectations of the interested parties list shall be as per the latest version of ***Context of the Organization*** (XYZ-TS-IS-RG-001).

4.3. Determining the scope of the information security management system

XYZ-TS shall define the scope and boundaries of the ISMS considering:

a) the external and internal issues referred to in 4.1;
b) the requirements referred to in 4.2; and
c) Interfaces and dependencies between activities performed by the organization, and those that are performed by other organization.

The scope is outlined in the latest version of ***ISMS scope document*** (XYZ-TS-IS-MN-002).

4.4. Information Security Management System

XYZ-TS shall establish, implement, maintain, and continually improve an information security management system, in accordance with the requirements of the ISO/IEC 27001:2013 standard.

CS5292 W6 · D02 · sanitised for teaching

5. Leadership

5.1. Leadership and Commitment

ISMC, represented by senior management from XYZ-TS will provide its commitment to the establishment, implementation, operation, monitoring, review, maintenance and improvement of the ISMS by:

a) ensuring the information security policy and the information security objectives are established and are compatible with the strategic direction of XYZ-TS.
b) ensuring the integration of the information security management system requirements into the XYZ-TS's processes.
c) ensuring that the resources needed for the information security management system are available.
d) communicating the importance of effective information security management and of conforming to the information security management system requirements.
e) ensuring that the information security management system achieves its intended outcome(s).
f) directing and supporting persons to contribute to the effectiveness of the information security management system.
g) promoting continual improvement; and
h) Supporting other relevant management roles to demonstrate their leadership as it applies to their areas of responsibility.

5.2. Policy

XYZ-TS shall establish an appropriate information security policy manual which addresses the requirements for information security and commitment on continual improvement in ISO/IEC 27001:2013 section 5.2. Information security policy manual shall be documented, communicated with the organization and made available to interested parties as appropriate.

5.3. Organization Roles, Responsibilities and Authorities

ISMC shall assign the roles and responsibilities relevant to information security shall be documented in XYZ-TS ***Information Security Roles & Responsibilities*** (XYZ-TS-IS-PR-018).

CS5292 W6 · D02 · sanitised for teaching

6. Planning

6.1. Actions to Address Risks and Opportunities

6.1.1. General

- In planning for the ISMS, XYZ-TS shall consider the external and internal issues that it faces and requirements by the interested parties.
- A systematic process shall be in place to determine the risks and opportunities and a method to manage the same in order to operate the ISMS without any failure.
- The approach shall also include on how to implement the actions to reduce risks and exploit opportunities. Further a method shall be inbuilt to evaluate the effectiveness of these actions.

6.1.2. Information Security Risk Assessment

- XYZ-TS shall establish an information security risk assessment process in the form of a procedure which contains the following:
    - Criteria for performing information security risk assessments;
    - Risk acceptance criteria;
    - Method to identify risks associated with the loss of confidentiality, integrity and availability;
    - Identify risk owners;
    - Method to assess the potential impacts if the risks were to materialize;
    - Method to assess the probability of the risk occurrence;
    - Method to calculate overall risk level; and
    - Method to prioritize risks for treatment.
- The risk assessment process shall be documented in XYZ-TS ***Information Risk assessment and Treatment plan*** (XYZ-TS-IS-RG-003) and approved by the ISMC.

6.1.3. Information Security Risk Treatment

- XYZ-TS shall establish an information security risk assessment process in the form of a procedure which contains the following:
    - Selecting appropriate risk treatment option to mitigate the risk to an agreed acceptable level;
    - Selecting controls for Annexure A of ISO/IEC 27001:2013 where applicable; and

CS5292 W6 · D02 · sanitised for teaching

  - Formulating a risk treatment plan.
- XYZ-TS shall document the Statement of Applicability mentioning the following.
  - Controls applicability;
  - Justification for inclusion and whether the control is implemented or not; and
  - Justification for exclusion.
- ISMC shall approve the risk treatment plan together with the risk owners (if the risk owner is outside the ISMC). The same has to approve the residual risk.
- The risk treatment process shall be documented in XYZ-TS ***Information Risk assessment and Treatment plan*** (XYZ-TS-IS-RG-003).

6.2. Information Security Objectives and Planning to Achieve Them

- XYZ-TS shall establish information security objectives aligning to the XYZ-TS's business strategy and IT strategy.
- Management shall ensure that objectives are measurable (if practicable), specific, relevant, attainable and time bound.
- The objectives shall be documented together with the following:
  - Action plan to achieve the objective;
  - Resources required to achieve the objective;
  - Responsible person;
  - Time plan; and
  - Evaluation criteria.
- The Objectives shall be documented in ***ISMS Objectives*** (XYZ-TS-IS-RG-002) and updated annually or as appropriate.

CS5292 W6 · D02 · sanitised for teaching

7. Support

7.1. Resources

- XYZ-TS management will determine and provide the appropriate resources needed to:
  - Establish, implement, operate, monitor, review, maintain and improve an ISMS;
  - Ensure that information security procedures support the business requirements;
  - Identify and address legal and regulatory requirements and contractual security obligations;
  - Maintain adequate security by correct application of all implemented controls;
  - Carry out reviews when necessary, and to react appropriately to the results of these reviews; and
  - Where required, improve the effectiveness of the ISMS.

7.2. Competence

- ISMC and ISO with support of HR, will ensure that all personnel who are assigned responsibilities defined in the ISMS are competent to perform the required tasks by:
  - Determining the necessary competencies for personnel performing work effecting the ISMS;
  - Providing training or taking other actions (e.g. employing competent personnel) to satisfy these needs;
  - Evaluating the effectiveness of the actions taken; and
  - Maintaining records of education, training, skills, experience and qualifications.

  The competence plan is outlined in the latest version of ***Competency plan document*** (XYZ-***TS-IS-MN-006).***

7.3. Awareness

- ISMC and ISO with support of HR will ensure that all relevant personnel are aware of the relevance and importance of their information security activities and they contribute to the achievement of the ISMS objectives.
  - Awareness shall be provided using multiple methods of communicating awareness and educating personnel (for example, posters, emails, banners, workshops and meetings);
  - Awareness training shall be conducted;

CS5292 W6 · D02 · sanitised for teaching

i. Upon hiring for new recruits (induction program); and

ii. Existing staff.

- New recruits shall acknowledge Acceptable Usage Policy at the time of joining, while HR will enforce existing employees that they have read and understand the information security policy; and
- Awareness session shall also include the contribution required by individuals to the effectiveness of the information security management system and implication for non-compliance to the XYZ-TS information security policies.

7.4. Communication

- XYZ-TS shall establish a communication plan relevant to internal and external communication on ISMS, containing the following at minimum:
  - What documented information to communicate and with whom to communicate;
  - Who will be responsible to communicate; and
  - When and how the communication shall happen.

  The competence plan is outlined in the latest version of ***Communication plan document*** (XYZ ***- TS- IS - MN - 007)***.

7.5. Documented Information

7.5.1. General

- ISMC, represented by senior management from XYZ-TS will ensure relevant documented information (policy, procedure, standard, guideline, record etc.) required by ISO/IEC 27001:2013 is available including:
  - Scope of the ISMS (clause 4.3);
  - Information security policy and objectives (clauses 5.2 and 6.2);
  - Risk assessment and risk treatment methodology (clause 6.1.2);
  - Statement of Applicability (clause 6.1.3 d);
  - Risk treatment plan (clauses 6.1.3 e and 6.2);
  - Risk assessment report (clause 8.2);
  - Records of training, skills, experience and qualifications (clause 7.2);
  - Monitoring and measurement results (clause 9.1);

CS5292 W6 · D02 · sanitised for teaching

- Internal audit program (clause 9.2);
- Results of internal audits (clause 9.2);
- Results of the management review (clause 9.3); and
- Results of corrective actions (clause 10.1).

- In addition to the above list ISMC shall also ensure that documented information determined by the organization which are required for the operations of the ISMS are also available as per ***Master List of Documents*** (XYZ-TS-IS-RG-015).

7.5.2. Creating and Updating

- In creating and updating documented information ISMC shall ensure the following are included at minimum:
  - Title of the documented information;
  - Date;
  - Author or creator of the documented information;
  - Reference number;
  - Reviewer details; and
  - Approver details.
- Documented information shall be in an approved template governed by the documented control procedure contained in the XYZ-TS ***Mandatory ISMS Procedures*** (XYZ-TS-IS-PR-002).
- Documented information shall be reviewed and approved by an authorized personnel as per their authority level.

7.5.3. Control of Documented Information

ISMC, represented by the senior management from XYZ-TS will establish, document, implement and maintain documented procedure to control and protect the documented information as required by the ISMS. This documented procedure covers management actions that are necessary to:

- approve documents for adequacy prior to issue.
- review and update documents as necessary and re-approve documents;
- ensure that changes and the current revision status of documents are identified;
- ensure that relevant versions of applicable documents are made available at points of use;

CS5292 W6 · D02 · sanitised for teaching

- ensure that documents remain legible and readily identifiable;
- ensure that documents are available to those who need them, and are transferred, stored and ultimately disposed-off in accordance with procedures applicable to their classification;
- ensure that documents of external origin are identified;
- ensure that distribution of documents is controlled;
- prevent unintended use of obsolete documents;
- Apply suitable identification to them if they are retained for any purpose; and
- Ensure appropriate document classification is placed by document owners.

Version controlling guideline shall be documented in ***Mandatory Information Security Management System (ISMS) Procedures*** (XYZ-TS-IS-PR-002).

CS5292 W6 · D02 · sanitised for teaching

8. Operation

8.1. Operational Planning and Control

- ISMC shall implement the actions determined after performing the risk assessment. ISMC shall:
  - Ensure processes and resources are in place to implement the actions;
  - Ensure that process are operating effectively by performing self-assessments; and
  - Implement the actions to achieve the information security objectives.
- Documented information shall be available as evidences to showcase that the processes are implemented and operated effectively.
- ISMC shall ensure changes are managed and controlled as per a documented change management process.
- ISMC shall identify the activities that are outsourced and ensure that controls are well in place as determined by the risk treatment plan.

8.2. Information Security Risk Assessment

- Risk assessment shall be performed on a pre-defined interval or any significant changes are proposed or occurred. This shall be documented in the risk assessment and treatment procedure.
- XYZ-TS shall retain documented information of the results of the information security risk assessments.

8.3. Information Security Risk Treatment

- ISMC shall identify responsible process owners to implement the risk treatment plan.
- Risk treatment plan shall contain target dates for the implementation and ISMC shall monitor the implementation of the action plan.
- XYZ-TS shall retain document information of the results of the information security risk treatment.

CS5292 W6 · D02 · sanitised for teaching

9. Performance Evaluation

9.1. Monitoring, Measurement, Analysis and Evaluation

- ISMC is responsible to evaluate the information security performance and the effectiveness of the ISMS.
- ISMC shall:
  - Determine the Key Performance Indicators (KPIs) related to information security;
  - KPIs consider the operational effectiveness of controls and processes;
  - The process of monitoring and measuring the KPIs;
  - Analyzing and evaluating the KPIs;
  - KPI monitoring and measuring intervals;
  - Responsibilities related to monitoring and measuring the KPIs;
  - Process of monitoring and measurements to be analyzed and evaluated; and
  - Responsibilities related to analyzing and evaluating the results.
- ISO will maintain an ***Information Security Dashboard*** (XYZ-TS-IS-RG-016) which will have matrices deriving from the above areas to determine the effectiveness of the ISMS.

9.2. Internal Audit

- ISMC and ISO will arrange to conduct internal ISMS audits at planned intervals to determine whether the established controls objectives, controls, processes, policies and procedures of ISMS:
  - Conform to the requirements of ISO/IEC 27001:2013 International Standard and relevant legislation or regulations; and
  - Conform to the identified information security requirements; and are effectively implemented, maintained and are performed as expected.
- Documented procedures will be established and maintained for planning and implementing internal ISMS audits to verify the effectiveness of the ISMS.
- Adequately qualified, trained internal auditors audit information security related activities at regular intervals as per the plan. Internal audit function shall be outsourced if suitably qualified auditors cannot be soured within XYZ-TS. Audits and corrective actions will be carried out in accordance with documented procedures and ISO maintains the records of all such audits completed along with the details of corrective / preventive actions initiated.
- Results of the internal audit shall be communicated to Senior Management.

CS5292 W6 · D02 · sanitised for teaching

- Documented information shall be in internal audit procedure contained in the ***Internal audit and corrective action procedure*** (XYZ-TS-IS-PR-019).

9.3. Management Review

- ISMC, represented by senior management from XYZ-TS will review the ISMS at planned intervals, at least once in a year, to ensure its continuing suitability, adequacy and effectiveness. During this review, ISMC will assess the opportunities for improvements and any need for change to ISMS, including policy and objectives. The results of such reviews will be recorded and maintained.
- Management review agenda topics shall include following:
    - The status of actions from previous management reviews;
    - Changes in external and internal issues that are relevant to the ISMS;
    - Feedback on the information security performance, including trends in:
        i. Nonconformities and corrective actions;
        ii. Monitoring and measurement results;
        iii. Audit results; and
        iv. Fulfillment of information security objectives.
    - Feedback from interested parties;
    - Results of risk assessment and status of risk treatment plan; and
    - Opportunities for continual improvement.
- The outputs of the management review shall include decisions related to continual improvement opportunities and any needs for changes to the ISMS.
- XYZ-TS shall retain documented information as evidence of the results of the management reviews.

CS5292 W6 · D02 · sanitised for teaching

10. Improvement

10.1. Nonconformity and Corrective Action

- A procedure for corrective action will be documented in ***Mandatory Information Security Management System (ISMS) Procedures*** (XYZ-TS-IS-PR-002), implemented and maintained that addresses the actions to eliminate the cause of the non-conformities with the ISMS requirements in order prevent the recurrence of such nonconformities. This procedure will include:
  - Process of how to react to the nonconformity including action to control and response to impact;
  - Evaluate to take further action to eliminate the root causes by performing a root cause analysis and determining a suitable action to ensure that non conformity not recur or occur elsewhere;
  - Implementation of the determined action;
  - Process of reviewing the effectiveness of the correction action taken; and
  - Changes required to ISMS if application.
- XYZ-TS shall retain documented information of the following:
  - Details of the nonconformity;
  - Actions taken with action implementer name and dates; and
  - Results of the action.

10.2. Continual Improvement

- ISMC and ISO will continually improve the effectiveness of ISMS through the application of:
  - Information security policies and procedures;
  - Information security objectives;
  - Internal or external audit results;
  - Events / incidents analysis;
  - Inputs from management review meetings;
  - Measurement of effectiveness of Implemented controls; and
  - Corrective and preventive actions.

CS5292 W6 · D02 · sanitised for teaching